

Exercise 01 – Insecure Service

1 Goals:

1. Perform Sniffing Attack
2. Be able to read the information sent between the browser and the webserver

2 Requirements:

1. Have Docker Desktop installed on your computer
2. Download provided source code with docker compose files to instantiate services
3. Use a sniffing tool to capture traffic. Examples include ***tcpdump***, ***tshark***, ***wireshark***
4. Have a browser installed

3 Steps:

3.1 Load Services

Load the services using Docker compose.

Use the command, in the directory where the docker-compose.yml file is stored:

```
docker-compose -f docker-compose.yml up --build
```

A successful run provides a web page with a form with three fields, as depicted in Figure 1.

i http://localhost:8080

Laboratory Exercise 01 - Insecure service

Provide the required data

Your Name: Your Email: Your Password:

Figure 1 - Form of Laboratory 1

3.2 Capture Traffic

Capture the traffic using a capturing tool like **tcpdump**, **tshark**. The following example uses tcpdump.

```
sudo tcpdump -i en0 -vvvv -n tcp port 8081 or tcp port 8080
```

You should be able to capture the packets, as follows:

```
192.168.68.57.8080 > 192.168.68.59.49666: Flags [P.], cksum 0x5d2c (correct), seq 1:204, ack 459, win 2048, options [nop,nop,TS val 2073921024 ecr 1361660937], length 203: HTTP, length: 203
  HTTP/1.1 200 OK
  Server: nginx/1.29.1
  Date: Sun, 14 Sep 2025 11:37:59 GMT
  Content-Type: application/json
  Content-Length: 49
  Connection: keep-alive

  {"Email":"testes","Name":"teste","Pass":"teste"}
12:37:59.610962 IP (tos 0x0, ttl 64, id 0, offset 0, flags [DF], proto TCP (6), length 52)
```

Figure 2 - Example of capture

4 Questions:

The following questions should be answered in your report, providing evidence (e.g., screenshots, HTTP status code, etc.) that support your reply.

1. Which security property is compromised, in this example?
2. Assuming that password is a sensitive field, which mechanisms would you propose to guarantee a secure storage in the server? A secure transmission of the password, to ensure its integrity?
3. You are responsible to deploy the form to collect the required data. Given the insecurity of the current deployment discuss a plan with your red team to secure the service (you do not need to implement the plan, but you need to provide enough details regarding the plan).
4. The red team needs to indicate how it would validate the provided plan.

Your report should be complete and provide evidence that you performed the several steps.